

Lab: File path traversal



TRAVERSAL SEQUENCES BLOCKED WITH ABSOLUTE PATH BYPASS

Luis Emmanuel Aronia Silva - 182979 - UPSLP

Mtro. Servando López Contreras



Septiembre 2026

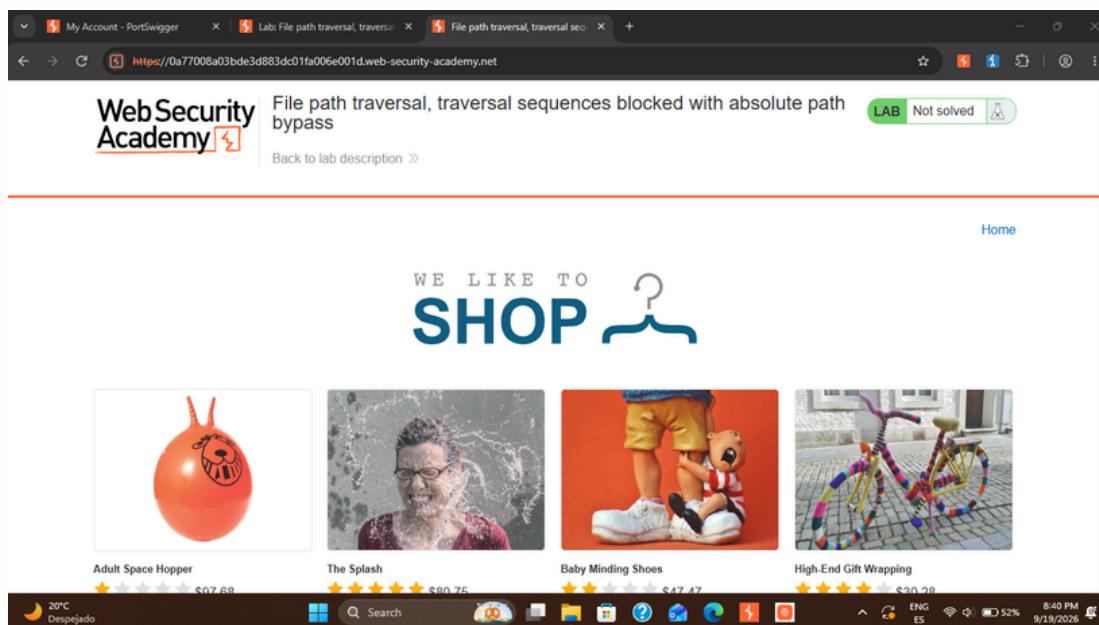
Parcial 1, Fundamentos de
Ciberseguridad

Lab: File path traversal

TRAVERSAL SEQUENCES BLOCKED WITH ABSOLUTE PATH BYPASS

Guia Documentada

Para realizar este Laboratorio primero hay que iniciar Burp Suite, una vez dentro hay que ir a la pestaña de Proxy, despues en Intercept, una vez en esa pestaña hay que abrir el navegador de la aplicacion y entrar con el enlace oficial del laboratorio, llegando asi a esta vista de una tienda online



Ahora se procede a capturar una peticion de una de las imagenes, regresando a Burp Suite y marcando el intercept en ON



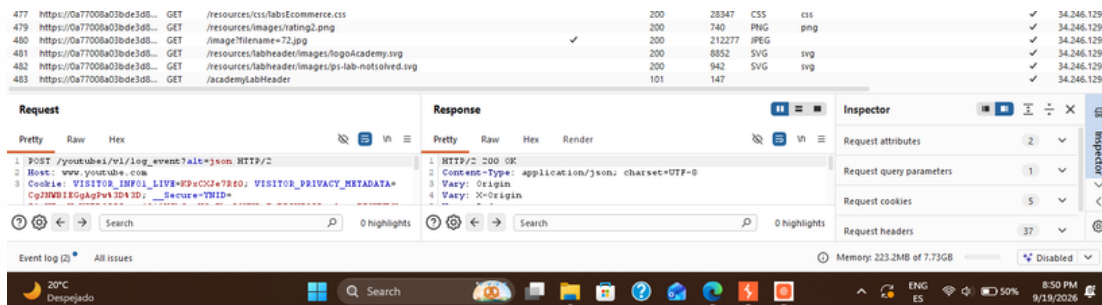


Lab: File path traversal

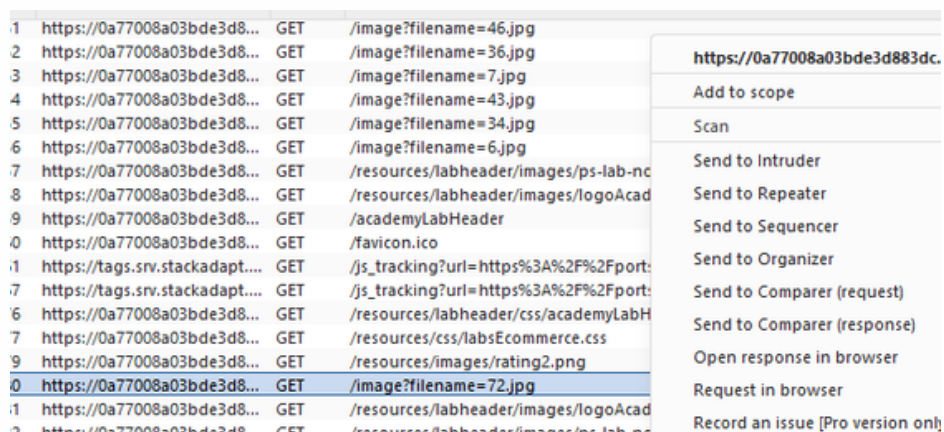
TRAVERSAL SEQUENCES BLOCKED WITH ABSOLUTE PATH BYPASS

Guia Documentada

Ahora hay que hacer click en alguna de las imagenes de productos, al hacerlo en Burp Suite en la parte de HTTP History deberiamos ver una peticion de este estilo: GET /image?filename=XX.jpg



Hacemos click derecho en la peticion y le damos a Sent to Repeater



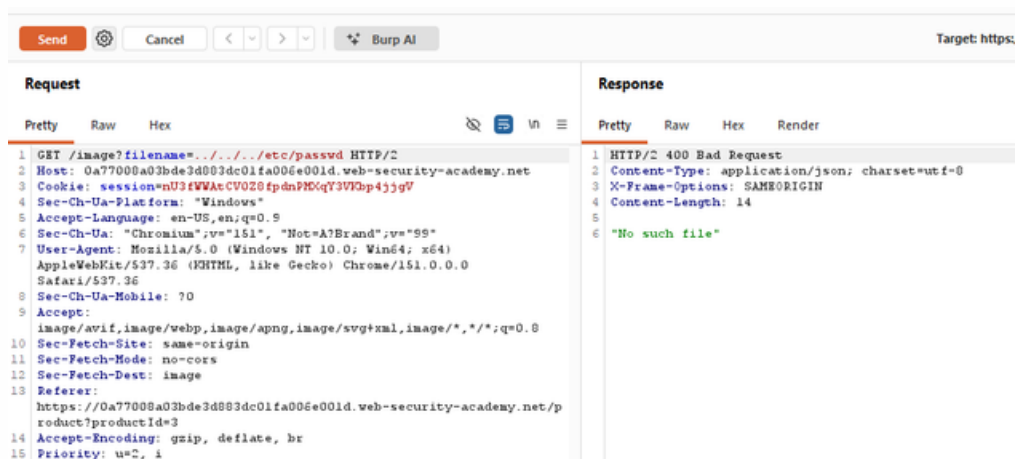


Lab: File path traversal

TRAVERSAL SEQUENCES BLOCKED WITH ABSOLUTE PATH BYPASS

Guia Documentada

Dentro de la pestaña de Repeater hay que cambiar el valor del filename `por lo siguiente: **../../../etc/passwd** y click en Send



El que haya aparecido el **No Such File** nos confirma que las cadenas **../** estan bloqueadas, debido a esto hay que cambiar el valor del filename de nuevo por el siguiente valor: **/etc/passwd** y nuevamente click en send



Lab: File path traversal

TRAVERSAL SEQUENCES BLOCKED WITH ABSOLUTE PATH BYPASS

Guia Documentada

Despues de ver esto y revisar el cuadro de Response de la derecha podemos ver que se ha devuelto el contenido completo del archivo `/etc/passwd`

The screenshot shows the Chrome DevTools network tab. A request to `https://0a77008a0bde3d003dc01fa00e001d.web-security-academy.net/product?id=3` is selected. The response is an `HTTP/2 200 OK` with `Content-Type: image/jpeg`. The response body is a list of system users from the `/etc/passwd` file, including `root:x:0:0:root:/root:/bin/bash`, `daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin`, `bin:x:2:2:bin:/bin:/usr/sbin/nologin`, `sys:x:3:3:sys:/dev:/usr/sbin/nologin`, `sync:x:4:65534:sync:/bin:/bin/sync`, `games:x:5:60:games:/usr/games:/usr/sbin/nologin`, `man:x:6:12:man:/var/cache/man:/usr/sbin/nologin`, `lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin`, `mail:x:8:8:mail:/var/mail:/usr/sbin/nologin`, `news:x:9:9:news:/var/spool/news:/usr/sbin/nologin`, `uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin`, `proxy:x:13:13:proxy:/bin:/usr/sbin/nologin`, `www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin`, `backup:x:34:34:backup:/var/backups:/usr/sbin/nologin`, `list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin`, `irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin`, `gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin`, `nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin`, `_apt:x:100:65534::/nonexistent:/usr/sbin/nologin`, `peter:x:12001:12001:/home/peter:/bin/bash`, and `carlos:x:12002:12002:/home/carlos:/bin/bash`.

This is a close-up of the response body from the previous screenshot. It shows the `/etc/passwd` file contents, listing system users and their home directories and shells. The list includes `root`, `daemon`, `bin`, `sys`, `sync`, `games`, `man`, `lp`, `mail`, `news`, `uucp`, `proxy`, `www-data`, `backup`, `list`, `irc`, `gnats`, `nobody`, `_apt`, `peter`, and `carlos`.

Lab: File path traversal

TRAVERSAL SEQUENCES BLOCKED WITH ABSOLUTE PATH BYPASS

Explicacion Tecnica

La aplicación implementa una defensa que bloquea las secuencias de recorrido (`../`)

Sin embargo, trata el nombre del archivo como relativo a un directorio de trabajo por defecto.

Cuando enviamos una ruta absoluta (`/etc/passwd`), el servidor la interpreta directamente desde la raíz del sistema de archivos (`/`), saltándose completamente el filtro que solo eliminaba o bloqueaba las secuencias `../`

Por eso el payload correcto es simplemente:

`/etc/passwd`

